Cetus Launchpad Smart Contract Audit Report

MOVEBIT

contact@movebit.xyz

https://twitter.com/movebit_

07/20/2023



Cetus Launchpad Smart Contract Audit Report

1 Executive Summary

1.1 Project Information

Description	A launchpad project.
Type	Launchpad
Auditors	MoveBit
Timeline	July 12, 2023 – July 20, 2023
Languages	Move
Platform	Sui
Methods	Architecture Review, Unit Testing, Manual Review
Source Code	https://github.com/CetusProtocol/cetus-launchpad
Commits	1effa6ac19e3b7cb2323eda3c684d1220f70a9e6 7d828063fccde5664fc251768023cb928c2429c5 e6cd9967c2e03dc1b4303055481db536358744d6

1.2 Files in Scope

The following are the SHA1 hashes of the initial reviewed files.

ID	Files	SHA-1 Hash
CFG	sui/IDO/sources/config.move	b65e5982c53f133d3ddc785a b1c43f9e201ae98c

DRA	sui/IDO/sources/duration.move	c866807b4eb52bebaa6f6dfd46fc4a812e5fc750
FTY	sui/IDO/sources/factory.move	77630f7d2fd25c74cd84eb02bf0acad88f6f716a
LK	sui/IDO/sources/lock.move	3d71a63cf7887a4de98aa9535ea1183e0075483a
OSP	sui/IDO/sources/oversubscribe_pool.move	83cc141b30d3c3067c2d793b103da83762544222
PM	sui/IDO/sources/purchase_manager.move	ed95147ad1d75898e69cd8befd24d068671878ba
WHT	sui/IDO/sources/whitelist.move	3a7162e3bc4b3c490375ce1bbbb34023ba688a12
MV	sui/IDO/Move.toml	e60cf89b565537e1b120749a65517acf1a15d0db

1.3 Issue Statistic

Item	Count	Fixed	Acknowledged
Total	6	6	
Informational			
Minor	4	4	
Medium			
Major	2	2	
Critical			

1.4 MoveBit Audit BreakDown

MoveBit aims to assess repositories for security-related issues, code quality, and compliance with specifications and best practices. Possible issues our team looked for included (but are not

limited to):

- Transaction-ordering dependence
- Timestamp dependence
- Integer overflow/underflow by bit operations
- Number of rounding errors
- Denial of service / logical oversights
- Access control
- Centralization of power
- Business logic contradicting the specification
- Code clones, functionality duplication
- Gas usage
- Arbitrary token minting
- Unchecked CALL Return Values
- The flow of capability
- Witness Type

1.5 Methodology

The security team adopted the "**Testing and Automated Analysis**", "**Code Review**" and "**Formal Verification**" strategy to perform a complete security test on the code in a way that is closest to the real attack. The main entrance and scope of security testing are stated in the conventions in the "Audit Objective", which can expand to contexts beyond the scope according to the actual testing needs. The main types of this security audit include:

(1) Testing and Automated Analysis

Items to check: state consistency / failure rollback / unit testing / value overflows / parameter verification / unhandled errors / boundary checking / coding specifications.

(2) Code Review

The code scope is illustrated in section **1.2**.

(3) Formal Verification

Perform formal verification for key functions with the Move Prover.

(4) Audit Process

- Carry out relevant security tests on the testnet or the mainnet;
- If there are any questions during the audit process, communicate with the code owner in time. The code owners should actively cooperate (this might include providing the latest stable source code, relevant deployment scripts or methods, transaction signature scripts, exchange docking schemes, etc.);
- The necessary information during the audit process will be well documented for both the audit team and the code owner in a timely manner.

2 Summary

This report has been commissioned by **Cetus** to identify any potential issues and vulnerabilities in the source code of the **Cetus Launchpad** smart contract, as well as any contract dependencies that were not part of an officially recognized library. In this audit, we have utilized various techniques, including manual code review and static analysis, to identify potential vulnerabilities and security issues.

During the audit, we identified **6** issues of varying severity, listed below.

ID	Title	Severity	Status
FTY-01	Code Optimization	Minor	Fixed
LK-02	Incorrect Ability in Event	Minor	Fixed
OSP-03	Unused Constants	Minor	Fixed
OSP-04	Incorrect Error Code	Minor	Fixed
PM-05	Lack of Validation for `ID` of `PurchaseManager` and `PurchaseCertificate`	Major	Fixed
PM-06	Lack of Validation for `Publisher`	Major	Fixed

3 Participant Process

Here are the relevant actors with their respective abilities within the **Cetus Launchpad** Smart Contract：

Admin

- Admin can update the `PackageVersion` to disable the package through `update_package_version()` .
- Admin can update the `DurationManager` through `update()` .
- Admin can create an oversubscribe pool through `create_oversubscribe_pool()` .
- Admin can add one white-listed address through `add_white_listed_address()` .
- Admin can add white-listed addresses through `add_white_listed_addresses()` .
- Admin can remove a white-listed address through `remove_white_listed_address()` .
- Admin can remove white-listed addresses through `remove_white_listed_addresses()` .
- Admin can update the white-listed address's protection limit through `update_white_listed_address()` .
- Admin can update the white-listed protection hard cap through `update_protection_hard_cap()` .
- Admin can update the pool owner address through `update_pool_owner()` .
- Admin can update the `DurationManager` in the pool through `update_pool_duration()` .
- Admin can Cancel the pool through `cancel()` .

User

- User can create a new `PurchaseCertificate` and purchase the `sale` coin through `create_certificate_and_purchase()` .
- User can purchase the `sale` coin through `purchase()` .
- User can redeem the obtained `sale` coin and the refunded `raise` coin through `redeem()` .

Pool Owner

- Pool Owner can withdraw the obtained `raise` coin and the refunded `sale` coin through `withdraw()` .
- Pool Owner can inject liquidity to the `clmm` pool through `inject_liquidity_with_forward_clmm_pool()` and `inject_liquidity_with_reverse_clmm_pool()` .

4 Findings

FTY-01 Code Optimization

Severity: Minor

Status: Fixed

Code Location: sui/IDO/sources/factory.move#L148

Descriptions: The code `if... .abort` can be optimized.

Suggestion: It is recommended to modify the code as: `!assert(!linked_table::contains(&pools.list, pool_key), EPOOL_ALREADY_INITIALIZED)`.

LK-02 Incorrect Ability in Event

Severity: Minor

Status: Fixed

Code Location: sui/IDO/sources/lock.move#L18, L26

Descriptions: The abilities of `LockNFTEvent` and `UnLockNFTEvent` are `copy`, `drop`, and `store`, for event objects only `copy` and `drop` are needed.

Suggestion: It is recommended to remove `store` ability.

OSP-03 Unused Constants

Severity: Minor

Status: Fixed

Code Location: sui/IDO/sources/oversubscribe_pool.move#L52

Descriptions: The constant `EClmmTickSpacingNotMatch` is not used.

Suggestion: It is recommended to remove the unused constant.

OSP-04 Incorrect Error Code

Severity: Minor

Status: Fixed

Code Location: sui/IDO/sources/oversubscribe_pool.move#L761, 805

Descriptions: The error code in `redeem` and `withdraw` function is incorrect, it should be `EPoolNotInClaimPeriod`.

Suggestion: It is recommended to modify the error code.

PM-05 Lack of Validation for `ID` of `PurchaseManager` and `PurchaseCertificate`

Severity: Major

Status: Fixed

Code Location: sui/IDO/sources/purchase_manager.move#L239

Descriptions: The function `update_for_purchase` does not check if the `PurchaseManager` and `PurchaseCertificate` belong to the same id. The method of attack is as follows: first we call the `create_certificate_and_purchase` function to make a normal purchase in order to get a correct `PurchaseCertificate`, then we call L168's `new` function to create a PurchaseManager, and then L175's `create_purchase_certificate` function to add the user's address to `purchase_manager` in order to pass L247's validation criteria and this function can be passed in any ID. Finally, we call the function update_for_purchase with the created `PurchaseManager`, the correct `PurchaseCertificate`, and the forged parameters `purchase_amount` and `remainer_protection_limit` to update the `purchase_raise_amount` and `protection_raise_amount` in the function. Since all the parameters of this function can be forged, the data in the `PurchaseCertificate` will be tampered with, and this attack method can successfully pass the id verification in the `redeem` function, then the credentials can be redeemed for profit.

Suggestion: It is recommended to verify that the ids of the `PurchaseManager` and `PurchaseCertificate` are the same.

PM-06 Lack of Validation for `Publisher`

Severity: Major

Status: Fixed

Code Location: sui/IDO/sources/purchase_manager.move#L129

Descriptions: There is a lack of validation for `Publisher` in the `setDisplay` function can lead to the function being called arbitrarily and modifying the display.

Suggestion: It is recommended to verify that the package in the `Publisher` is the same as the current contract.

Appendix 1

Issue Level

- **Informational** issues are often recommendations to improve the style of the code or to optimize code that does not affect the overall functionality.
- **Minor** issues are general suggestions relevant to best practices and readability. They don't post any direct risk. Developers are encouraged to fix them.
- **Medium** issues are non-exploitable problems and not security vulnerabilities. They should be fixed unless there is a specific reason not to.
- **Major** issues are security vulnerabilities. They put a portion of users' sensitive information at risk, and often are not directly exploitable. All major issues should be fixed.
- **Critical** issues are directly exploitable security vulnerabilities. They put users' sensitive information at risk. All critical issues should be fixed.

Issue Status

- **Fixed:** The issue has been resolved.
- **Partially Fixed**: The issue has been partially resolved.
- **Acknowledged:** The issue has been acknowledged by the code owner, and the code owner confirms it's as designed, and decides to keep it.

Appendix 2

Disclaimer

This report is based on the scope of materials and documents provided, with a limited review at the time provided. Results may not be complete and do not include all vulnerabilities. The review and this report are provided on an as-is, where-is, and as-available basis. You agree that your access and/or use, including but not limited to any associated services, products, protocols, platforms, content, and materials, will be at your own risk. A report does not imply an endorsement of any particular project or team, nor does it guarantee its security. These reports should not be relied upon in any way by any third party, including for the purpose of making any decision to buy or sell products, services, or any other assets. TO THE FULLEST EXTENT PERMITTED BY LAW, WE DISCLAIM ALL WARRANTIES, EXPRESS OR IMPLIED, IN CONNECTION WITH THIS REPORT, ITS CONTENT, RELATED SERVICES AND PRODUCTS, AND YOUR USE, INCLUDING BUT NOT LIMITED TO THE IMPLIED WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE, NOT INFRINGEMENT.

